

Security Incident Report

Cloudora Security Operations | CLD-IR-0001 | Incident Report

Report ID	CLD-IR-0001
Related ticket	CLD-0001 - Suspicious sign-in activity: daniel.reeve@cloudora.io
Report title	Executive account takeover via password spray, with MFA persistence and BEC staging
Analyst	SOC Analyst, Cloudora engagement (MyFirstHack training)
Date of report (UTC)	2026-08-10
Incident severity	P1 - executive mailbox compromised during an active enterprise deal; fraud staging in place
Status	Contained - eradication verified, monitoring continues
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Between August 8th and 10th, an external attacker launched a low-volume password guessing attempt across 26 distinct Cloudora staff accounts using three IP addresses from Lagos, Nigeria. On August 10th, the attacker compromised two accounts: the CEO (Daniel Reeve, 03:12:05 UTC) and a staff member (Priya Nair, 03:47:18 UTC). The attacker registered their own authentication device on the CEO's account and created a hidden inbox rule that hides finance and invoice related emails to set up for future invoice frauds. The compromise was detected the same morning, leading to both accounts being successfully contained, the attacker's authentication device and inbox rules being removed, the source IP addresses from Lagos being blocked. There was no evidence of any damage in the available logs and the other 24 accounts that were targeted but not breached had their passwords reset as a precaution.

2. Incident timeline

Time (UTC)	Source	Event	Evidence / notes
Aug 8, 2026, 00:00-05:00	Sign-in	1st Attempt at Password Spray	44 failed sign-in attempts across 20 different accounts (1-3 attempts per account) from 102.89.x.x
Aug 9, 2026, 00:00-05:00	Sign-in	2nd Attempt at Password Spray	36 additional failed sign-in attempts across 19 different accounts from the same source IPs
Aug 10, 2026, 00:35:22-03:10:41	Sign-in	3rd Attempt at Password Spray	More failed sign-in attempts; 3 failed attempts at daniel.reeve@cloudora.io from 102.89.44.17
Aug 10, 2026, 03:12:05	Sign-in	Successful Sign-in to daniel.reeve	102.89.44.17 successfully signs into daniel.reeve@cloudora.io in Chrome 125 on a Windows 10
Aug 10, 2026, 03:14:30	Sign-in	daniel.reeve mailbox accessed	102.89.44.17 accesses daniel.reeve mailbox via Outlook Web
Aug 10, /2026, 03:18:44	Audit	MFA persistence	Attacker adds device 'Pixel 6' as authenticator app to mailbox
Aug 10, 2026, 03:26:02	Sign-in	daniel.reeve session opens Azure Portal	102.89.44.17 opens Azure Portal through daniel.reeve
Aug 10, 2026, 03:31:09	Audit	New Inbox Rule 'RSS Subscriptions' Created	Attacker creates a new inbox rule that moves any mail from finance@cloudora.io or containing 'invoice' to 'RSS Subscriptions' and marks them as read
Aug 10, 2026, 03:44:55	Sign-in	Failed Attempt at priya.nair	Attacker fails sign-in attempt on priya.nair@cloudora.io
Aug 10, 2026, 03:47:18	Sign-in	Successful Sign-in to priya.nair	Attacker compromises a second account priya.nair@cloudora.io in Chrome 125 on Windows 10
Aug 10, 2026, 03:52:40	Sign-in	SharePoint Online accessed	102.89.45.101 accesses SharePoint Online through priya.nair
Aug 10, 2026, 08:41:00	Sign-in	Daniel Reeve genuine Sign In	Sign In to daniel.reeve from London, UK (203.0.113.11, macOS 14), less than 5 hrs apart from his previous sign in Lagos, Nigeria
Aug 10, 2026, 08:55	Ticket	CLD-0001 ticket raised	IT admin flags the suspicious sign-in activity due to impossible travel and investigation starts
Aug 10, 2026, ~11:00	Response	Containment executed on both accounts	See section 7 for more details

3. Findings

Finding 1: The CEO account was accessed by an attacker from Lagos, Nigeria, not by Daniel travelling.

On Aug 10 at 03:12:05 UTC, there was a successful sign-in to daniel.reeve@cloudora.io from Lagos, Nigeria on a Windows 10 / Chrome 125 device that has never been seen in use before. Prior to this, the account was exclusively signed in from London, United Kingdom on a macOS/Safari device. On 08:41 UTC of the same day, another sign-in activity from London, United Kingdom with the usual device was detected. Travel can be ruled out due to the impossible time difference between the two sign-in activities as well as the unusual time, and the unfamiliar device fingerprint.

Finding 2: CEO account was compromised by password spraying

Between Aug 8th and Aug 10th, three Lagos IPs 102.89.x.x failed 114 sign-in attempts across 26 accounts (44 attempts across 20 accounts on Aug 8th, 36 attempts across 19 accounts on Aug 9th, and 34 attempts across 18 accounts on Aug. 10th). Each account only had one to three sign-in attempts per night to avoid the possible lockout threshold, which is a sign of password spraying.

Finding 3: Attacker established MFA persistence on the CEO account

At 03:18:44, the audit logs show "Authenticator app added: device 'Pixel 6'". The attacker establishes MFA persistence (T1098.005) on the Outlook App after getting initial access to the account, which would allow their access to persist even through password resets.

Finding 4: Attacker staged a BEC inbox rule for invoice fraud

At 03:31:09, the attacker creates a new inbox rule "Rule 'RSS Subscriptions': if from finance@cloudora.io or contains 'invoice' -> move to RSS Feeds, mark read". By redirecting these emails, the attacker can hide the conversations from the mailbox owner and later run invoice fraud from the CEO account undetected.

Finding 5: A second account priya.nair was compromised the same way

At 03:47:18, a Lagos IP 102.89.45.101 gets access to priya.nair@cloudora.io as well as SharePoint Online a few minutes later. Based on previous sign-in activity, the account has only been signed in from London, United Kingdom. Although there are no audit logs indicating any actions taken by the attacker, the same containment steps as the CEO account are applied.

Finding 6: omar.farah's activity in Dubai is due to legitimate travel and is a false positive

SignIn logs show activity of omar.farah@cloudora.io in Dubai between Aug 8th and Aug 10th. However, given the time of these activity which are during the usual work hours of 9:00 AM to 6:00 PM and the use of the same device iOS 17/ Mobile Safari (which has also been used in London, United Kingdom) across all Dubai activity, these sign-in activities are due to consistent travel and not compromise. This account was also targeted by the password spray but there are no indications of device compromise.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IPv4	102.89.45.101	Aug 8, 2026 02:22:31	Lagos IP used in password spraying; compromised priya.nair account
IPv4	102.89.44.23	Aug 8, 2026 04:21:04	Lagos IP used in password spraying
IPv4	102.89.44.17	Aug 8, 2026 03:52:43	Lagos IP used in password spraying; compromised CEO account, MFA registration, inbox rule
Device/User Agent	Windows 10 / Chrome 125	Aug 8, 2026	DeviceOS and Browser consistently used through password spray attempts
MFA Device	Pixel 6	Aug 10, 2026 03:18:44	Device added as authenticator app to mailbox - removed
Inbox Rule	RSS Subscriptions	Aug 10, 2026 03:31:09	BEC inbox rule created for invoice fraud - deleted

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
Credential Access	T1110.003	Brute Force: Password Spraying	Finding 2: 114 failed sign-in attempts across 26 accounts in 3 nights
Initial Access	T1078	Valid Accounts	Finding 1 and 5: successful login using password spray
Persistence	T1098.005	Device Registration (MFA)	Finding 3: attackers added own authenticator 'Pixel 6'
Defense Evasion	T1564.008	Hide Artifacts: Email Hiding Rules	Finding 4: inbox rule 'RSS Subscriptions'

6. Scope

Accounts confirmed compromised

On Aug 10th, daniel.reeve@cloudora.io was compromised at 03:12:05 UTC and priya.nair@cloudora.io at 03:47:18 UTC from Lagos IPs 102.89.x.x as evidenced by successful sign-ins in CloudoraSignIn_CL.

Accounts targeted but not breached

24 distinct accounts were targeted with password spraying but were not compromised. These accounts only require precautionary password resets:

alba.vega, amelia.frost, aria.reid, cole.burke, dina.said, emma.hayes, ethan.wells, freya.lynn, gwen.muir, isla.grant, joel.kerr, jude.ross, kian.patel, leah.stone, lena.voss, liam.doyle, mira.shah, nina.cole, omar.farah, rhys.owen, ruth.dean, ryan.boyd, seth.lane, sofia.marino

Accounts investigated and cleared (false positives)

omar.farah@cloudora.io showed Dubai sign-ins but were assessed as legitimate travel and cleared.

7. Actions taken

Time (UTC)	Action	Performed by	Verified how
Aug 10, 2026 ~9:00	Revoked all active sessions for daniel.reeve and priya.nair	IT Admin/SOC Analyst	No live sessions from 102.89.x.x found after revoking sessions
Aug 10, 2026 ~9:30	Reset credentials for the compromised accounts	IT Admin/SOC Analyst	Credentials required to re-authenticate the accounts after reset
Aug 10, 2026 ~9:45	Removed attacker MFA device 'Pixel 6' from daniel.reeve; Reviewed priya.nair MFA methods and no attacker device found	IT Admin/SOC Analyst	'Pixel 6' is no longer registered as a MFA device in daniel.reeve
Aug 10, 2026 ~10:00	Deleted inbox rule 'RSS Subscriptions' from daniel.reeve; Review priya.nair inbox rules and found no further rules	IT Admin/SOC Analyst	'RSS Subscriptions' inbox not found in mailbox. Mails from finance@cloudora.io or containing 'invoice' do not get redirected and appear as unread in mailbox
Aug 10, 2026 ~10:30	Blocked IPs 102.89.x.x that were involved in password spraying	IT Admin/SOC Analyst	Confirm that the IPs 102.89.x.x are in the blocked list of the firewall/network configuration
Aug 10, 2026 ~11:00	Verified all previous steps. No 102.89.x.x activity found after containment	IT Admin/SOC Analyst	No sign-in activities of 102.89.x.x found after blocking IPs.

8. Recommendations

1. Create a password spraying detection rule: alert if one source IP tries to sign-in to multiple accounts in a small period of time. Scheduling this rule every few hours will help catch password spraying much earlier. (Finding 2)
2. Require MFA on all accounts. Even if password spraying guesses the correct password, MFA will be there to stop the compromise. (Finding 3)
3. Create alerts for any new MFA device or inbox rule that are registered/created. This will prevent attacker persistence with unauthorized devices and inbox rules from going unmonitored. (Finding 3 and 4)
4. Prevent access from countries with no business presence. This will prevent any undesired and unexpected traffic from causing problems. (Finding 1, 5, and 6)

9. Lessons learned

Password Spray detection was missing and required human action to notice impossible traveling patterns through sign-in activities. If there was a basic password spray alert, this would have notified the team about the widespread failed sign-in attempts from the same source IP. The feasibility of traveling patterns could be detected through a baseline comparison between a missed detection and a false positive. Looking for the same patterns also helped find a second account that was compromised the same way as the CEO account. Checking audit logs ensured that containment did not miss any backdoors or rules that could have later resurfaced the same issues.